

Guidance to BYOD



What is Bring Your Own Device?

Bring Your Own Device (BYOD) is a widespread term for when an organisation allows staff to use their own laptops, tablets or phones for work purposes.

In addition to mobile or remote devices owned by the organisation, user-owned devices which access work related data or services are in scope for Cyber Essentials and they will need to have security controls applied to them. This does not include mobile or remote devices that are use only for the purpose of : text messages, voice calls or multi-factor authentication applications. This means that if you have a mobile phone that you use to text or speak to work colleagues and receive MFA codes, but you do not use it to access your work emails or files, then that mobile phone is out of scope. If you use a mobile device to access your work emails, that device is in scope.

Although there may be significant financial savings to be had by allowing staff to use personal computers and phones for work, there are also some serious risks to an organisation's security and privacy.

If your employees, contractors or volunteers use their own devices for work, what are the risks to your organisation?

By allowing remote access to your organisation by devices that you do not control (non-organisation-owned computers and phones), you increase the risk of material being used by someone for purposes you may not authorise or agree. Company information could be copied, modified, transferred to your competitors or just made public.

For example, while a member of staff is working from their own computer, it is possible that a social media app recently downloaded or already active could access and use the work contact database, sharing identifiable information of clients which, by law, would need their consent to pass onto a third party. This could inadvertently result in a **data protection** violation.

Another risk is that the owner of the computer may install apps from insecure sources, perhaps not even realising the risks, and this could make your organisation's files vulnerable to attacks from **malware**. Failing to update a device can also leave it open to security threats.

Your employee who owns the computer may leave their device lying around unsecured (after all, they are probably working from home). They may allow friends and family to use it. Other issues include controlling the content and access of a private device if your employee leaves your company or sells their device, and erasing your organisational information if the device is lost or stolen.

Take back control and protect your information

The easiest thing you can do is write and enforce a **Bring Your Own Device (BYOD) policy**. This might be in addition or incorporate other key policies like IT Acceptable Use Policy, IT Security Policy, and Mobile Working Policy.

A BYOD policy does not have to be a complicated document, it should address the use of personal devices that connect to organisational networks, whether that be physical or cloud services eg Microsoft 365. In relation to apps, the policy is only concerned with those apps that interact with organisational data and services.

The employee/ owner of the device must understand and accept the terms and conditions of the BYOD policy . Inclusion of their BYOD device is conditional on their compliance with the rules.

It's important to note that an organisation cannot use a written policy to substitute applying controls to a BYOD device; technical measures also need to be in place.

Here are some suggestions that could be included in the policy:

The Operating System and apps must be fully supported by the manufacturer and receive security updates

Software based firewalls are activated and configured correctly

Security updates must be installed within 14 days

Cyber Essentials password controls are applied to users own devices (BYODs)

Users logging in on computers and tablets have a day-to-day account, and this is separate to the administrator account

The device automatically locks when not in use and requires a 6 digit or more pin/pass code to unlock, (use a **biometric** if available)

Anti-malware software is installed on devices and kept updated or, for a mobile device, only apps from the manufacture's respective store are allowed to be installed

.. . . .

Unused apps should be uninstalled

If lost or stolen, it must be reported to the business promptly

Rooting or **jailbreaking** is not permitted

A remote erase and tracking app must be installed and activated so you can track a lost device, lock access and erase data. Obtain written consent in advance from the device owner to remote wipe the device in the event of loss, theft or termination of employment

Clarify how, when and why monitoring will take place and require the device and passwords to be delivered up on reasonable request

For further risk reduction

Container Apps or Managed Apps are types of software that separate the organisation's data and personal data on the device and would enable the organisation to limit monitoring and remote wiping to company data only.

Mobile Device Management software (MDM) allows you to monitor, manage, and secure employees' mobile devices. There are different software models ranging in price.

Desktop virtualisation software, such as Citrix, allows employees to securely access data stored on the corporate network using their own device. Organisational data is accessed remotely and stays on a secure server. It may be necessary for staff to agree not to copy the organisation's data onto their own device.

So, before allowing private computers and phones to access your business information, be aware of the hidden costs (subscription, updates, limitations) and risks around your data and make a balanced judgement. If this is a subject you need support with, seek advice from an independent IT security service company.

© The IASME Consortium Ltd 2024 All rights reserved.